

INTERNATIONAL CYBERSECURITY AND
DIGITAL FORENSICS ACADEMY

Week 3 Practical Laboratory

Roles, Responsibilities and Accountability in Security Governance

TechGlobal Governance Transformation Simulation

By

Miracle Nwadiaru

GRC101_C11/26/CGRCE/17587

Evidence Bundle 1 – Governance Architecture and Stakeholder Map

1.1 Governance Gap Assessment

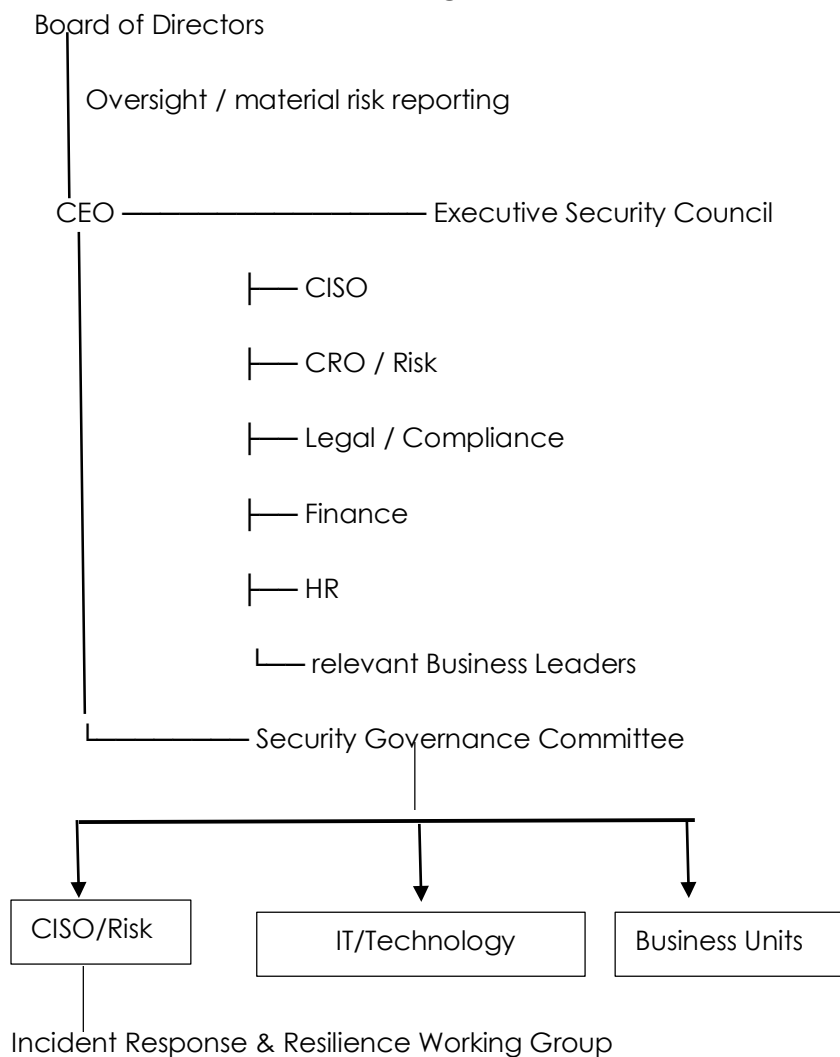
Weakness	Evidence from scenario	Business / risk consequence
1. Concentration of authority	The IT Director is effectively security owner, risk approver and operational decision-maker.	Creates a single point of authority and increases the chance that operational priorities override independent risk challenge.
2. No formal governance committee	There is no structured forum for Security, Risk, Legal, Finance, HR, IT and business leaders to make cross-functional decisions.	Important decisions may be made in isolation, with inconsistent priorities and weak challenge.
3. Inconsistent business-unit decisions	Business units make local security choices without a common governance mechanism.	Controls may differ across offices, creating uneven exposure and making enterprise-wide assurance difficult.
4. Weak Board visibility	The CEO and Board receive limited visibility into cyber risk.	Material risk may not be considered alongside strategy, risk appetite, investment and reputation.
5. Unclear risk ownership	The scenario identifies weak control ownership and informal escalation.	When a control fails, teams may disagree about who must remediate, accept or escalate the risk.
6. Limited escalation path	There are no reliable escalation routes from operational teams to executive management and the Board.	Issues can remain at operational level longer than appropriate, delaying decisions on material exposure.

1.2 Stakeholder Map

Stakeholder	Authority / influence	Primary interest	Information needed	Governance contribution
Board of Directors	High	Oversight, risk appetite, material cyber risk, reputation, assurance	Material risks, trends, significant incidents, risk acceptance, assurance results	Challenge management, set oversight expectations, review material risk
CEO	High	Strategic alignment, growth, acceptable risk, performance	Enterprise cyber posture, major decisions, financial/business impacts	Executive accountability; resolve cross-functional trade-offs
CISO	High	Security strategy, policy, risk oversight, programme effectiveness	Risk profile, control performance, incidents, programme status	Lead security governance; coordinate security programme
CRO / Risk	High	Enterprise risk integration, methodology, risk acceptance, aggregation	Risk ratings, treatment status, KRIs, accepted risks	Provide independent risk challenge and aggregation
Legal / Compliance	High	Regulatory, contractual, privacy and notification obligations	Applicable obligations, incidents, evidence, contracts	Advise on legal exposure and notification decisions
Finance	Medium–High	Budget, loss exposure, investment prioritisation	Business case, cyber losses, programme costs	Support investment governance and financial controls
HR	Medium	Joiner/mover/leaver, awareness, conduct and disciplinary processes	People-control metrics, training, access lifecycle exceptions	Own people governance controls and

				accountability processes
IT / Technology	High operationally	Technology delivery, secure operation, technical controls, continuity	Architecture, vulnerabilities, incidents, service performance	Implement and operate technical controls
Business Unit Leaders	High for own services	Operational performance, local risk and control implementation	Process risks, exceptions, control performance, business impact	Own business risks and implement agreed controls

1.3 Security Governance Organization Chart





Operational teams / control owners

1.4 Justification

The proposed architecture is appropriate for TechGlobal because its size and geographic spread make informal security decision-making difficult to control. With approximately 2,500 employees across five offices, security cannot reasonably depend on one executive or one technology function to make every significant decision. The model creates a clear distinction between ownership, oversight, advice and execution. This is consistent with the scenario's learning objective of linking Board oversight, executive leadership, security management and business units.

NIST CSF 2.0 places explicit emphasis on governance, including leadership accountability, established roles and authorities, resource allocation and integration of cyber security with organizational practices. This supports moving security governance away from an IT-only model. The CISO remains central to security leadership, but risk acceptance and enterprise aggregation are not treated as purely technical decisions. The CRO/Risk function provides enterprise risk challenge, while Legal/Compliance addresses legal and regulatory obligations. Business leaders retain responsibility for the business consequences of their processes. This creates a practical separation between the person operating a control and the people who challenge, approve or accept the associated risk.

The committee model is deliberately lean. TechGlobal does not need a large collection of committees that slow decisions. The Security Governance Committee is the main cross-functional forum, with an Executive Security Council reserved for strategic matters, significant exceptions and material risk. A single specialized working group focuses on incident response and resilience because incidents require coordinated technical, legal, communications, business continuity and executive decisions. Business Unit leaders participate through

representatives and risk owners rather than creating independent security committees in each office.

Finally, the architecture improves Board visibility without turning the Board into an operational security team. The Board receives a concise risk view covering material cyber risks, trend information, significant incidents, accepted exposures, major control weaknesses and management actions. Operational detail remains with management. This supports effective oversight while preserving appropriate management accountability.

Evidence Bundle 2 – Governance Responsibility and Authority Matrix

2.1 Responsibility Profiles

Role	Purpose	Core responsibilities	Decision authority	Reports / escalates	KPIs / evidence
Board	Independent oversight of material cyber risk	Approve/monitor risk appetite and material risk; challenge management; review major incidents and assurance	Approve Board-level risk appetite; oversee material risk; require management action	Receive periodic cyber-risk report and immediate material-risk escalation	Quality of Board cyber reporting; % material risks with treatment/owner
CEO	Executive accountability for enterprise cyber governance	Set strategic expectations; approve major priorities; resolve enterprise trade-offs	Approve enterprise direction, major investments and significant risk decisions within delegated authority	Escalate material matters to Board	Closure rate of executive actions; governance decisions completed on time

CISO	Lead cybersecurity governance and programme	Security strategy, policy, architecture standards, control oversight, reporting	Approve security standards within delegated authority; recommend risk treatments	Report posture, incidents, KRIs and programme status	Control effectiveness trend; critical vulnerability SLA compliance
CRO / Risk	Integrate cyber risk into ERM	Risk methodology, independent challenge, risk aggregation, treatment and acceptance process	Challenge ratings; approve/re record risk decisions where delegated	Report aggregate exposure and overdue treatments	% risks with owners/treatments; overdue high-risk actions
Legal / Compliance	Provide legal/regulatory assurance	Regulatory interpretation, contractual requirements, privacy, evidence and notification advice	Advise/approve legal positions within mandate; support notification decisions	Escalate legal/regulatory exposure and deadlines	Regulatory obligations tracked; notification decisions documented
Finance	Govern financial exposure and investment	Budget, business cases, losses, prioritization and financial controls	Approve funding within delegated authority; challenge cost assumptions	Report material losses and budget variance	Security budget variance; benefits/controls funded as approved
HR	Own people-related	Joiner/mover/leaver, awareness, conduct and	Approve HR processes and disciplinary	Report access lifecycle and	JML completion rate; security

	governance controls	disciplinary processes	actions within mandate	training exceptions	awareness completion
IT	Operate and implement technology controls	Secure operations, architecture implementation, patching, service continuity	Approve operational changes within technical mandate; implement authorized controls	Report incidents, vulnerabilities, service risks and exceptions	Critical vulnerabilities remediated within SLA; availability/recovery metrics

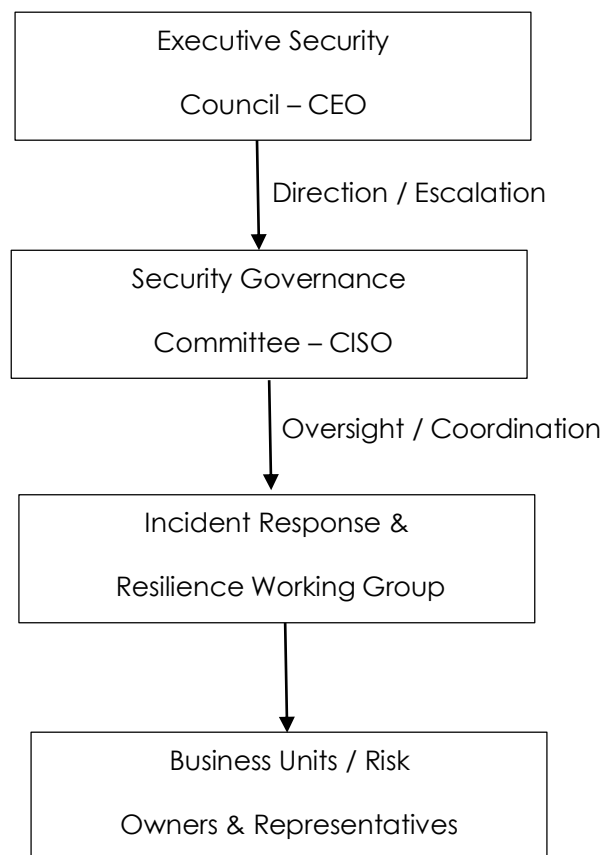
2.2 Key Authority Conflicts and Resolution

Overlap	Potential problem	Resolution principle
CISO vs IT	CISO sets security requirements while IT implements them; conflict may occur when a technical control affects delivery speed or service availability.	CISO owns security standards and governance; IT owns implementation. Exceptions require documented risk assessment and approval outside the implementer where practicable.
CRO/Risk vs business owner	Risk may challenge a business unit's preferred risk acceptance position.	Business owns the underlying risk; CRO/Risk independently challenges the assessment and confirms the decision is within delegated authority. Material or out-of-appetite risks escalate.
Legal vs CISO during incidents	Security may want rapid technical action while Legal may need evidence preservation and notification assessment.	Incident command remains operationally clear. Legal is an adviser on obligations/evidence; regulatory notification is a cross-functional decision with documented authority.

Finance vs security investment	Security may request urgent funding while Finance challenges affordability or prioritization.	Use a documented business case and risk-based prioritization. Emergency spend follows delegated emergency authority, with retrospective review.
--------------------------------	---	---

Evidence Bundle 3 – Security Governance Committee Ecosystem

3.1 Committee Structure



3.2 Terms of Reference – Security Governance Committee

Element	Requirement
Purpose	Provide a cross-functional forum for security governance decisions, risk treatment and monitoring.

Scope	Cyber-security policy, risk, control performance, architecture governance, third-party security, incidents, awareness, vulnerability oversight and resilience.
Membership	CISO (Chair), CRO/Risk, Legal/Compliance, Finance, HR, IT and nominated Business Unit representatives.
Frequency	Monthly, with extraordinary meetings for significant incidents or material decisions.
Quorum	Chair plus representatives from Risk and at least two other core functions, including Legal/Compliance when legal or regulatory matters are on the agenda.
Decision rights	Approve matters delegated to the Committee; recommend material decisions to the Executive Security Council; record decisions and owners.
Escalation	Material risks, out-of-appetite risks, unresolved cross-functional conflicts and significant incidents move to the Executive Security Council and, where applicable, Board oversight.
Records	Agenda, papers, attendance, decisions, rationale, action owners, due dates and review dates are retained in a controlled governance repository.
Review	Terms of Reference reviewed annually or after a material governance change.

3.3 Sample Agenda

- ✓ Previous minutes and action review.
- ✓ Cyber-risk dashboard and changes in enterprise exposure.
- ✓ Critical vulnerabilities and overdue remediation.
- ✓ Significant incidents and lessons learned.
- ✓ Third-party security exceptions.
- ✓ Policy and standards approvals.

- ✓ Security architecture or major technology changes.
- ✓ Awareness, joiner/mover/leaver and access governance metrics.
- ✓ Risk acceptance requests and escalation decisions.
- ✓ Matters requiring Executive Security Council or Board attention.

3.4 Sample Decision Log

Date	Decision / issue	Decision owner	Decision rationale	Actions / owner	Review date
15 Jan 2027	Approve temporary exception for legacy system vulnerability	CISO / CRO	System cannot be upgraded within current release window; compensating controls documented	IT to implement network restriction; Risk to review residual exposure	15 Feb 2027
12 Feb 2027	Require enhanced security review for critical third parties	Security Governance Committee	Third parties with privileged access create elevated dependency and access exposure	Procurement and IT to update onboarding checklist	12 Mar 2027
12 Mar 2027	Escalate unresolved high cyber risk to Executive Security Council	CRO / Risk	Treatment overdue beyond agreed tolerance and business impact increased	Business owner to present treatment plan; CEO to confirm direction	26 Mar 2027

3.5 12-Month Governance Calendar

Month	Recurring governance activity / milestone
January	Annual strategy and risk appetite review; approve governance priorities

February	Policy review; third-party risk deep dive
March	Board cyber-risk report; incident response exercise
April	Quarterly risk review; vulnerability trend analysis
May	Security awareness and HR control review
June	Mid-year security investment and architecture review
July	Business continuity / recovery exercise
August	Third-party assurance and contractual review
September	Enterprise cyber-risk reassessment
October	Board cyber-risk report; annual incident simulation
November	Budget and security programme planning
December	Annual governance effectiveness review; next-year calendar and priorities

Evidence Bundle 4 – RACI Accountability Matrix

Keys:

R = Responsible

A = Accountable

C = Consulted

I = Informed.

Activity	Board	CEO	CISO	CRO/Risk	Legal	Finance	HR	IT	BU Leader
Cybersecurity strategy approval	I	A	R	C	C	C	I	C	C
Security policy approval	I	A	R	C	C	I	C	C	C

Enterprise cyber-risk assessment	I	I	R	A	C	I	C	C	R
Risk acceptance	I	A*	C	R	C	I	I	C	R
Security budget approval	I	A	R	C	I	R	I	C	C
Security architecture approval	I	I	A	C	C	I	I	R	C
Third-party security review	I	I	A	C	C	C	I	R	R
Access governance	I	I	C	A	C	I	R	R	R
Incident response governance	I	A	R	C	C	I	C	R	C
Material incident escalation	I	A	R	C	C	I	I	R	C
Regulatory notification decision	I	A*	C	C	R	I	I	C	I
Security awareness programme	I	I	A	C	C	I	R	C	R
Vulnerability remediation oversight	I	I	A	C	I	I	I	R	C
Business continuity / recovery governance	I	A	C	R	C	C	C	R	R

Board cyber-risk reporting	A	R	R	R	C	C	I	C	C
----------------------------	---	---	---	---	---	---	---	---	---

4.1 RACI Problem Assignments and Implementation Guide

Three assignments require particular attention. First, risk acceptance should not be treated as a technical approval by IT. The business owner identifies the exposure, while Risk provides independent challenge and aggregation. The CEO or delegated authority accepts material exposure within the approved risk appetite, with Board oversight for material or out-of-appetite matters.

Second, regulatory notification should not be decided by the CISO alone. Legal obligations, available evidence, affected individuals, regulatory requirements and contractual commitments may all be relevant. Legal/Compliance should lead the legal assessment, while the appropriate executive authority makes the organizational decision where required.

Third, access governance requires coordination between HR, IT, business owners and Risk. No single function should create, approve and independently review privileged access without appropriate oversight.

Managers should use the RACI before activities begin rather than waiting for disputes. During planning, the project owner should confirm the Accountable and Responsible roles and ensure that required Consulted parties are available. During approvals, the Accountable role makes the decision, supported by documented evidence and rationale.

During incidents, the same principles apply, although emergency procedures may shorten consultation. Emergency decisions should be documented and reviewed afterwards. The RACI should also be reviewed whenever responsibilities, systems, organizational structures or risk appetite change.

Evidence Bundle 5 – Cyber-Risk Escalation and Segregation of Duties

5.1 Major Cyber-Risk Escalation Workflow

Detection or identification → record issue in risk/incident register → validate facts and business impact → assign risk owner → classify severity → apply operational containment/treatment → compare exposure with escalation thresholds → escalate to Executive Security Council when executive criteria are met → escalate to Board oversight for material or out-of-appetite risk → record decision, owner, treatment and deadline → monitor remediation → independent review/assurance → formally close with evidence.

Level	Example trigger	Decision authority	Required notification	Response time
Level 1 – Operational	Limited impact, contained exposure, no material regulatory/reputational effect, within approved tolerance	Operational manager / control owner with CISO or Risk oversight	Relevant manager, CISO/Risk	Same business day or agreed SLA
Level 2 – Executive	Significant business disruption, high residual risk, repeated control failure, major financial exposure, cross-office impact or risk outside delegated tolerance	CEO / Executive Security Council	CISO, CRO/Risk, Legal/Compliance, affected executives	Immediate escalation; executive review within 24 hours for active incidents
Level 3 – Material / Board	Material cyber incident, significant legal/regulatory exposure, prolonged critical service disruption, material financial/reputational effect, or risk outside Board-approved appetite	CEO with Board oversight; Board decision where reserved matters apply	Board, CEO, CISO, CRO/Risk, Legal/Compliance and relevant executives	Immediate notification once threshold is reasonably established

5.2 Segregation-of-Duties / Accountability Weakness Register

ID	Weakness / conflict	Risk created	Roles involved	Recommended control	Residual risk / review
1	IT Director controls security ownership, risk approval and operational execution	Self-approval and weak independent challenge	IT Director, CISO, Risk	Separate security governance from technology operations; require Risk/CEO approval for material risk acceptance	Residual conflict monitored through committee and assurance review
2	IT could propose, implement and close a major security exception	Exception may be closed without independent validation	IT, CISO, Risk	Risk validates residual exposure; CISO confirms technical controls; business owner accepts business impact	Periodic exception review
3	Business units make local security decisions without central governance	Inconsistent controls and duplicated decisions	BU Leaders, CISO, Risk	Central standards plus delegated local implementation; material exceptions centrally recorded	Quarterly exception reporting
4	Incident response could be controlled by the same team that caused or owns the affected system	Potential conflict over severity, evidence or closure	IT, Incident Lead, Legal, Risk	Incident command separated from system ownership where practicable; post-incident review independent of	Lessons-learned assurance

				incident operator	
5	Privileged access approval and implementation could sit with one team/person	Unauthorized or excessive access may be difficult to detect	IT, HR, BU Leader	Business owner approves need; IT provisions; periodic independent review by Risk/Security	Access recertification and exception monitoring
6	Regulatory notification assessment could be treated as a technical decision	Legal obligations and evidence requirements may be missed	CISO, Legal, CEO	Legal leads regulatory assessment; CISO provides facts; executive authority records final decision	Notification decision log and legal sign-off

5.3 Decision Recording and Assurance Note

Every significant governance decision should be properly documented and assigned a unique reference number. The record should include the date, issue statement, risk rating, decision owner, authority used, evidence considered, alternatives reviewed, decision rationale, agreed actions, action owners, due dates and review dates. It should also clearly state whether the matter was within the approved risk appetite and whether any exception or deviation was authorized.

Risk and Internal Audit or other assurance functions should be able to trace each decision from the originating incident or identified risk through approval, implementation and eventual closure. This ensures that decisions are transparent and can be reviewed when required.

Closure should not simply mean that an action has been marked as completed. The control owner should provide sufficient evidence to demonstrate that the

agreed action was implemented. The accountable governance role should then confirm that the treatment adequately addressed the original decision or risk. For high-risk or material matters, Risk or an independent assurance function should perform additional validation where appropriate.

Repeated overdue actions, recurring exceptions or worsening Key Risk Indicators (KRIs) should trigger further review or escalation. This approach creates a clear audit trail and enables management to identify recurring or systemic weaknesses instead of treating each incident as an isolated matter.

Conclusion

TechGlobal's main governance challenge is not the absence of security controls, but rather the concentration of decision-making authority and the lack of clarity around who is responsible for key decisions. The proposed governance model addresses this by clearly distributing authority across the Board, executive management, security leadership, enterprise risk, Legal/Compliance, Finance, HR, IT, and business owners.

The Security Governance Committee provides a structured forum for cross-functional decision-making, while the Executive Security Council and the Board provide appropriate escalation and oversight for matters that exceed operational authority or require strategic attention.

The RACI model further clarifies responsibilities and makes accountability more visible across the organization. However, its effectiveness will depend on managers using it consistently as a practical decision-making tool rather than simply as a documented framework. Similarly, the defined escalation thresholds should be applied consistently and supported by proper documentation and decision records.

Overall, these measures provide TechGlobal with a governance structure that can support its operations across five offices while avoiding unnecessary layers of bureaucracy. The proposed approach also aligns with the governance principles emphasized in NIST CSF 2.0 and the broader, integrated governance approach outlined in COBIT 2019.

References

1. NIST. (2024). The NIST Cybersecurity Framework (CSF) 2.0. National Institute of Standards and Technology, Cybersecurity White Paper 29.
2. NIST. (2024). NIST Cybersecurity Framework 2.0 – Frequently Asked Questions. National Institute of Standards and Technology.
3. ISACA. (2019). Tips for Implementing COBIT in a Continuously Changing Environment. ISACA Journal / Industry News.
4. ISACA. (2020). COBIT 2019 and the IIA 2019 Guiding Principles of Corporate Governance. ISACA.
5. ISACA. (2021). A Systematic Approach to Implementing a Governance System Using COBIT 2019. ISACA.